

EVIDENCE BUNDLE 1

Security Documentation Hierarchy Definition Table

Document type	Purpose	Authority	Mandatory / Recommended Nature	Level of detail
Policy	Defines the organisation's security objectives, principles, management direction and mandatory expectations. It explains what must be achieved and why.	Approved by senior leadership, executive management or the Board.	Mandatory. Employees and relevant third parties are required to comply.	High level. Focuses on business requirements, responsibilities and security goals instead of technical instructions.
Standard	Defines specific mandatory requirements, rules or minimum controls needed to support policies. It explains what acceptable implementation looks like.	Approved by IT management or relevant governance committees.	Mandatory. Compliance is required unless an approved exception exists.	Medium detail. More specific than policies and may include technical requirements.
Procedure	Provides step by step instructions for carrying out security activities. It explains how to perform a task.	Usually created and maintained by operational teams such as IT, Security Operations or System Administrators.	Mandatory when referenced by a policy or standard.	High detail. Contains workflows, processes, roles, tools and specific actions.
Guideline	Provides recommendations, best practices and advice to help users make secure decisions. It explains preferred approaches.	Usually issued by security teams, IT departments or subject matter experts.	Recommended unless a policy explicitly makes it mandatory.	Low to medium detail. Flexible guidance that allows professional judgement.

Categorisation of the Eight Statements

Statement	Classification	Justification
All NexusTech employees must use multi-factor authentication (MFA) when accessing the corporate network remotely.	Standard	This establishes a mandatory security requirement defining what users must do to protect remote access.
To configure MFA on your mobile device, download the Authenticator app, scan the QR code provided in the IT portal,	Procedure	This provides step-by-step instructions explaining how employees complete MFA setup.

and enter the six-digit verification code.		
It is recommended that developers use parameterised queries to reduce SQL injection risk	Guideline	This provides a recommended secure coding practice rather than a compulsory organisational requirement.
NexusTech is committed to protecting the confidentiality, integrity and availability of all client data.	Policy	This communicates the organisation's overall security commitment and strategic objective.
All corporate laptops must have full-disk encryption enabled using BitLocker (Windows) or FileVault (macOS).	Standard	This specifies a mandatory technical control and approved encryption methods for company devices.
Employees should avoid connecting to public, unsecured Wi-Fi networks when travelling.	Guideline	This advises employees on safer behaviour but does not define a strict mandatory control.
In the event of a suspected security breach, employees must immediately contact the IT Helpdesk at extension 5555.	Procedure	This defines the required action and communication step during a security incident.
Passwords must be a minimum of 14 characters and contain at least one uppercase letter, one lowercase letter, one number and one special character	Standard	This defines specific measurable password requirements that systems and users must follow.

Security Policy Hierarchy Diagram

